jamk

Artificial Intelligence (AI) Security Risk Management

Framework for SMEs, including startups.

Muhammad Khubaib

Master's thesis
November 2025
Master's Degree Program in Information Technology, Cyber Security

jamk | Jyväskylän ammattikorkeakoulu
University of Applied Sciences

jamk

Description

Muhammad Khubaib

AI Security Risk Management Framework for SMEs including Startups.

Jyväskylä: JAMK University of Applied Sciences, November 2025, 40 pages.

Degree Program in Information Technology, Cyber Security. Master's thesis.

Permission for open access publication: Yes

Language of publication: English

Abstract

Artificial intelligence (AI) has rapidly adopted in Small and Medium-sized Enterprises (SMEs) due to innovation, operational efficiency, effectiveness and market competence. This rapid adoption of AI also opened the doors for hackers to take advantage of AI that introduced important cybersecurity and regulatory issues for SMEs. To tackle these cyber security issues related to AI, a need was identified for a lightweight AI security risk management framework that would allow SMEs including startups to manage AI security risks effectively within the limited technical and financial resources.

Although, there were many frameworks exist for AI security risk management but were not tailored only specifically for SMEs. Main idea was to identify the gaps in existing risk management frameworks, standards and guidelines to make fit for small and medium-sized companies within the limited resources. The research focused on the literature view approach followed by framework synthesis and comparative analysis with existing frameworks standards and guidelines including NIST AI RMF (2023), ISO/IEC 42001 (2023), and ENISA AI Security Framework (2023). These frameworks were analyzed and identified best practices on the basis of SMEs needs and designed a new AI security risk management framework based on four functions: Govern, identify, assess and strengthen that address risk governance, identification, assessment and continuous improvement.

Based on comparative analysis the results illustrated that new AI Security risk management framework (AIS-RMF) fulfill the needs of SMEs based on resource efficiency, scalability, simplicity and regulatory alignment within that limited technical capacity. It was concluded that the new AI risk management framework provides scalable foundation for SMEs and startups to manage AI risks without excessive financial and administrative burden. AIS-RMF improves trust and transparency in AI adoption and sporting the organizational maturity in alignment with industries standards.

Keywords/tags (subjects)

AI Security, AI risk management, cyber security, Information security, AI risk management framework

Miscellaneous (Confidential information)

No confidentiality requirements.

Contents

1 Introduction 4
1.1 Problem statement 5
1.2 Purpose of the study 6
1.3 Research objectives 7
1.4 Research questions 7
2 Background and Key Concepts 7
2.1 Artificial intelligence and its security implications 8
2.2 Risk management concepts 8
2.3 Review of existing frameworks and standards 9
2.3.1 ISO/IEC 27005 – Information Security Risk Management (ISMS) 9
2.3.2 ISO/IEC 42001 – AI management system standard 10
2.3.3 NIST AI Risk Management Framework (AI RMF) 11
2.3.4 ENISA AI cybersecurity guidelines 12
2.3.5 European Union Artificial Intelligence Act 13
2.3.6 OECD and AI ethics guidelines 13
2.3.7 IEEE and sectoral standards 14
2.3.8 Other relevant frameworks and research models 14
2.4 Challenges for SMEs and startups 19
2.5 Research gap and conceptual basis for the framework 19
3 Methodology 20
3.1 Research design 20
3.2 Research approach 20
3.3 Data collection method 21
3.3.1 Literature review 21
3.4 Data analysis 22
3.5 Validity and reliability 22
3.6 Ethical considerations 23
4 Proposed Framework 23
4.1 Framework core 23
4.2 Function 1: Governance 24
4.3 Function 2 – Identify: 27
4.4 Function 3 – Assess: 32
4.4.1 Risk analysis: 32

4.4.2 Risk evaluation: 33
4.4.3 Risk quantification 33
4.4.4 Outcome and alignment 33
4.5 Function 4 – Strengthen: 36
5 Evaluation and Discussion 38
5.1 Evaluation approach 38
5.2 Key objectives of evaluation 39
5.3 Evaluation criteria 40
5.4 Evaluation methodology 41
5.5 Comparative analyses with existing frameworks 42
5.5.1 AI governance and accountability 42
5.5.2 Risk identification and mapping 42
5.5.3 Data security and privacy 42
5.5.4 Model robustness, fairness, and performance 43
5.5.5 Resource efficiency and simplicity 43
5.5.6 Regulatory alignment and compliance 44
5.5.7 Monitoring and continuous improvement 44
5.5.8 Summary of findings 44
5.6 Alignment with research objectives 45
5.7 Limitations and recommendations for future research 46
6 Conclusion 47
6.1 Summary of the research 47
References 50

Figures

Figure 1: ISO/IEC 27005 – Information Security Risk Management (ISO, 2022) 10
Figure 2: ISO/IEC 42001 – AI Management System Standard process (International Organization for Standardization, 2023) 11
Figure 3: NIST ARMF (National Institute of Standards and Technology [NIST], 2023) 12
Figure 4: EU AI Act (EU's Artificial Intelligence (AI) Act - Civilsdaily, 2023) 13
Figure 5: AIS-RMF (AI Security Risk Management Framework) 23

Tables

Table 1: Enterprise categories 4
Table 2: Function 1 - Governance 25

Table 3: Machine learning Threats 28
Table 4: Function 2 - Identify 30
Table 5: Function 3 - Assess 34
Table 6: Function 4 - Strength 36
Table 7: Evaluation Criteria 40
Table 8: Evaluation Results 45

AI	Artificial Intelligence
SME	Small and Medium-sized Enterprise
AIS-RMF	Lightweight AI Security Risk Management Framework
NIST	National Institute of Standards and Technology
ENISA	European Union Agency for Cybersecurity
EU AI Act	European Union Artificial Intelligence Regulation
ISO/IEC 42001	Artificial Intelligence Management System Standard
Risk Register	Document listing identified risks, likelihoods, and impacts
Bias Mitigation	Techniques to reduce algorithmic or data-driven bias in AI systems

1 Introduction

In today's era, every organization is using Artificial Intelligence (AI) and taking advantage of AI to boost their business and bring innovation and creativity to compete with competitors. AI culture is also rapidly growing in small and medium enterprises and startups to grow their business and bring innovations and technology for market leadership (Žigienė et al.,2019).

AI systems are now playing a very important role in business operations and improving business activities with automation and innovations. The vast use of AI systems is also increasing different kinds of threats that are different from traditional IT security risks. AI systems are also exposing internal data due to misconfigurations and a lack of technological advancement. There are many risks in AI systems, like data poisoning, model inversion, adversarial manipulation, and extraction attacks that are very dangerous for business (Zeijlemaker et al.,2025).

Definition of small and medium enterprises, including startups:

According to the European Commission Recommendation 2003/361/EC, Small and Medium Enterprises are defined under three conditions: Number of employees, annual turnover, or balance sheet total, which reflects the company category. These categories are mentioned in Table 1, which explains that if the company has fewer than 10 employees and the annual turnover or balance sheet total is less than €2 million, this type of company falls under the category of micro enterprises. So, if a company have fewer than 50 employees and a turnover of less than €10 million, it falls under small enterprises. Medium enterprises have fewer than 250 employees, and an annual turnover is less than €50 million (European Commission, 2003). Small and Medium Enterprises (SMEs) are categorized as follows:

Table 1: Enterprise categories

Category	Employees	Annual Turnover or Balance Sheet Total
Micro Enterprise	Fewer than 10	≤ €2 million
Small Enterprise	Fewer than 50	≤ €10 million
Medium Enterprise	Fewer than 250	≤ €50 million turnover or ≤ €43 million balance sheet total

Startups often fall under the condition of the micro and small enterprise category due to limited resources, fewer employees, and limited financial capabilities, because startups are newly established organizations that need to scale rapidly through AI, innovation, technology, and market distribution (European Startup Network, 2022). Security and compliance challenges amplify in startups due to high uncertainty and limited governance maturity (OECD, 2021).

So in this research, the focus is on those companies that have fewer than 250 employees and an annual turnover of less than €50 million, which covers small, medium, and micro enterprises.

Due to limited resources and a lack of technical capabilities of small and medium enterprises face many serious cybersecurity and governance issues (Sotamaa et al.,2023). Due to a lack of resources, small organizations cannot manage their risk management activities because the existing risk management frameworks only exist for large enterprises and government entities (Sarker et al.,2025). So, small and medium enterprises are facing advanced AI threats and cannot resolve them within limited resources. This could be the result of data breaches and the operational disruption of the business and compliance, and regulations issues.

So, there is a need for an AI security risk management framework that can help small and medium organizations, including startups, to measure the AI security risk within limited resources and technical expertise. This increases the need for an AI security risk management framework that would be lightweight, stable, and easy to implement for medium and small enterprises.

1.1 Problem statement

There are so many AI frameworks already existing in the market, such as ISO/IEC 42001, ISO/IEC 27005, the NIST AI Risk Management Framework, and ENISA's AI Cybersecurity Guidelines. These standards are very difficult to customize and implement for small and medium-sized companies; it's mainly designed for large corporations and government sectors. Small and medium organizations often need scalable, easy to adopt with fewer resources to be implemented for security (Sarker et al., 2025).

SMEs and startups, by contrast, often lack:

- Dedicated cybersecurity and governance teams.
- Budget and time to conduct thorough AI risk assessments.
- Awareness of legal and ethical AI requirements (e.g., GDPR, EU AI Act).
- Documentation and audit capacity required for regulatory compliance.

This gap raises the need for an AI security risk management framework that is customized for smaller and medium-sized organizations to easily adopt within the limited resources and technical abilities. So, without this structured framework, SMEs face a lot of security threats and risks as well as regulatory and compliance issues (Somer & Thalmann, 2023).

Hence, with the growing use of AI, we need a simplified, resource-efficient AI security risk management framework that fully aligns with international standards as well as fulfills the needs of small and medium organizations, including startups, to meet regulatory and compliance requirements.

1.2 Purpose of the study

The purpose of this research is to develop an AI security risk management framework that is lightweight and easy to use for small and medium organizations with limited resources and technical expertise. The framework will be fully aligned with international standards and will fulfill the needs of small and medium organizations to compete with the market, as well as fulfill the compliance and regulatory requirements. This framework will adopt guidelines and procedures from existing frameworks and guidelines, such as ISO, NIST, and ENISA, to simplify the process of risk management. This framework will also strengthen the security of the organizations against AI threats in advance.

The framework aims to:

- Establish a systematic approach of AI Security Risk management for SMEs and startups.
- Comply with international standards and best practices.
- Prepare a defence against AI security threats.

- Lightweight, easy to use with limited resources.

1.3 Research objectives

To achieve the study's purpose, the following objectives are established:

1. To study and analyse existing AI security risk management frameworks, standards, and guidelines.
2. To identify gaps between existing frameworks and analyse how to fix AI security-related risks in SMEs and startups.
3. To build a lightweight and scalable AI Security risk management framework suitable for SMEs.
4. To evaluate the proposed framework.

1.4 Research questions

This research addresses the following questions:

1. What are the key AI security risks that affect SMEs and startups?
2. Which component of existing frameworks fulfills the needs of SMES?
3. How to simplify an AI Security risk management framework for SMEs and startups?
4. How proposed version can full fill the needs of SMEs?

2 Background and Key Concepts

This chapter presents the basic concepts for developing an AI Security Risk Management framework for SMEs. It begins with the introduction of AI, how companies are using and taking advantage of AI, and how AI can have bad impacts on their infrastructure and can expose their internal data, infrastructure, or disturb their business operations. This chapter will also include the study of well-known standards and guidelines that address the AI security risk management

framework. Finally, it will identify and analyze the existing research gaps and will highlight why SMEs require an AI security risk management framework.

2.1 Artificial intelligence and its security implications

AI systems are bringing advancement in industries by enabling innovation, productivity, analytics, affordable and efficient solutions. As AI systems have been growing and embedded with business operations, and facing high-level security vulnerabilities and issues. Unlike traditional IT systems, AI models are heavily dependent on data and algorithms, which can be compromised by attackers due to the lack of technical expertise or misconfigurations in terms of data poisoning, adversarial attacks, model inversion, and model theft attacks(Zeijlemaker et al., 2025).

- Data poisoning is the malicious activity where an attacker manipulates training data to change model behavior (Sotamaa et al., 2023).
- Adversarial attack is a type of AI attack where an attacker attacks on model weaknesses and compromises through modification of input that causes incorrect outputs (Sarker et al., 2025).
- Model inversion is a type of attack where an attacker can compromise the interface and reveal sensitive data or metadata of the business, proprietary model information (Somer & Thalmann, 2023).

AI is also facing ethical and governance risk issues that can cause regulatory and compliance concerns that are against the law. These ethical exploitations exist due to the lack of explainability and privacy concerns. These risks are very critical in the sense of SMEs that depend mostly on third-party tools or lack of technical expertise to manage them effectively (Žigienė et al., 2019).

2.2 Risk management concepts

Risk management is a structured process of managing risk using different phases that include identifying the risk, assessing that risk, and mitigate the risk that could impact the organization's objectives and goals (ISO/IEC 27005:2022). This process includes five main stages:

1. Risk Identification: Identify potential risks and vulnerabilities.

2. Risk Assessment: Analyzing the likelihood and impact of identified risks as per business objectives.
3. Risk Treatment: Control implementation to mitigate or eliminate risks.
4. Risk Monitoring: Reviewing continuously the effectiveness of controls.
5. Communication and Documentation: Document all processes and procedures and ensure to share with relevant stakeholders.

These are the stages that must account for AI systems to maintain data dependency, algorithm transparency, and model life cycle management (Sarker et al., 2025). Traditional AI risk management frameworks don't focus on these dimensions or concepts, which is the main difference. But the AI risk management framework focuses on these dimensions that make it unique in nature.

2.3 Review of existing frameworks and standards

This section summarizes the existing frameworks, standards, and guidelines related to AI security risk management and covers how procedures and processes deal with risks.

2.3.1 ISO/IEC 27005 – Information Security Risk Management (ISMS)

For a standard risk management approach, most companies are using ISMS, which is information security risk management by ISO/IEC 27005:2022 (Figure 1) based on ISO/IEC 27001, which only emphasizes and provides the standard guidelines for establishing, maintaining, and continuously improving the risk management approaches within an organization's information security risk management systems and it also emphasize the assessment, control selections and improvement of these procedures (International Organization for Standardization [ISO], 2022).

Although this framework offers strong foundations, it only focuses on information security risks but does not cover specific threats related to AI models, such as adversarial manipulation or data leakage. This is a very efficient way to mitigate the risk, but it's not focused on AI, and it also does not provide a summarized approach for small and medium identifications to make a defense system against AI threats (Sotamaa et al., 2023).

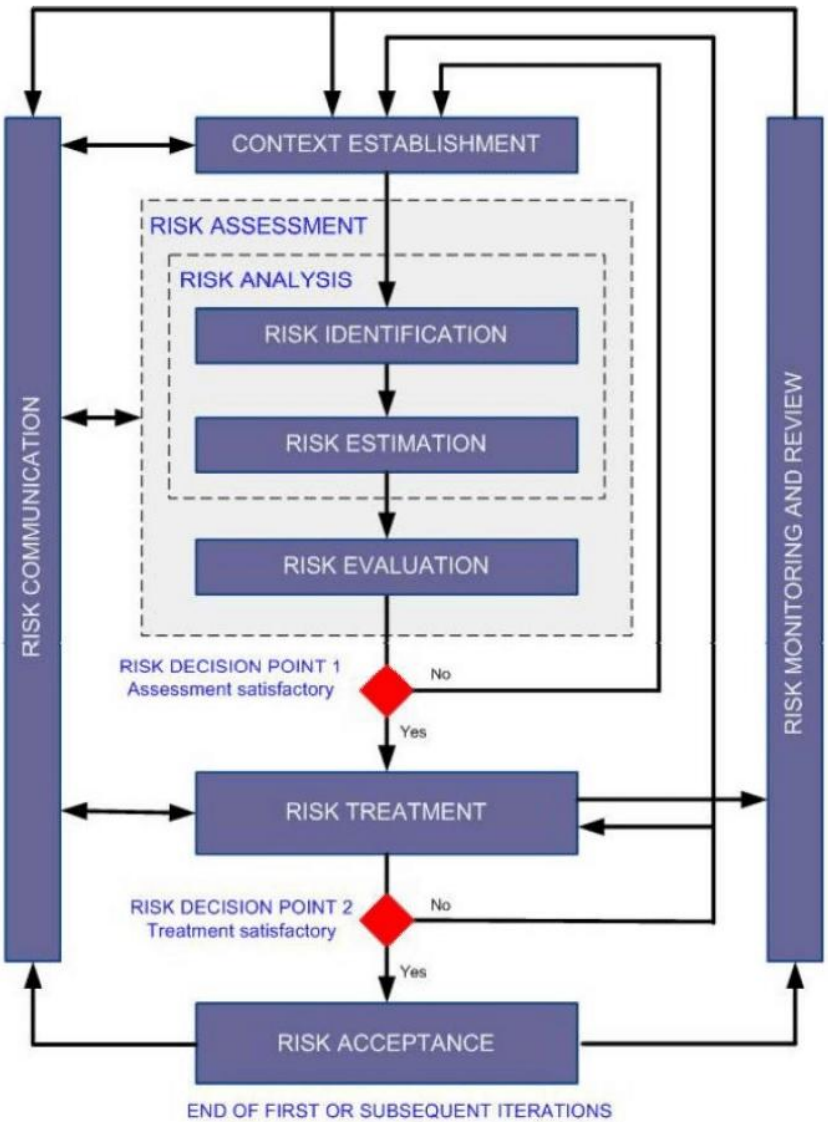

Figure 1: ISO/IEC 27005 – Information Security Risk Management (ISO, 2022)

2.3.2 ISO/IEC 42001 – AI management system standard

ISO/IEC 42001:2023 is a governance framework specially designed for an artificial intelligence management system (AIMS) that (Figure 2) focuses on AI management and provides full guidelines and procedures for developing, deploying, and maintaining AI infrastructure throughout the AI lifecycle. It ensures the safety, transparency, and accountability of the AI system (ISO, 2023).

Although ISO/IEC 42001 is the first international standard designed only for AI management. But it's designed for only those organizations that have maturity in the governance and compliance

department. SMEs can face struggles to implement this due to the complexity and cost of certifications.

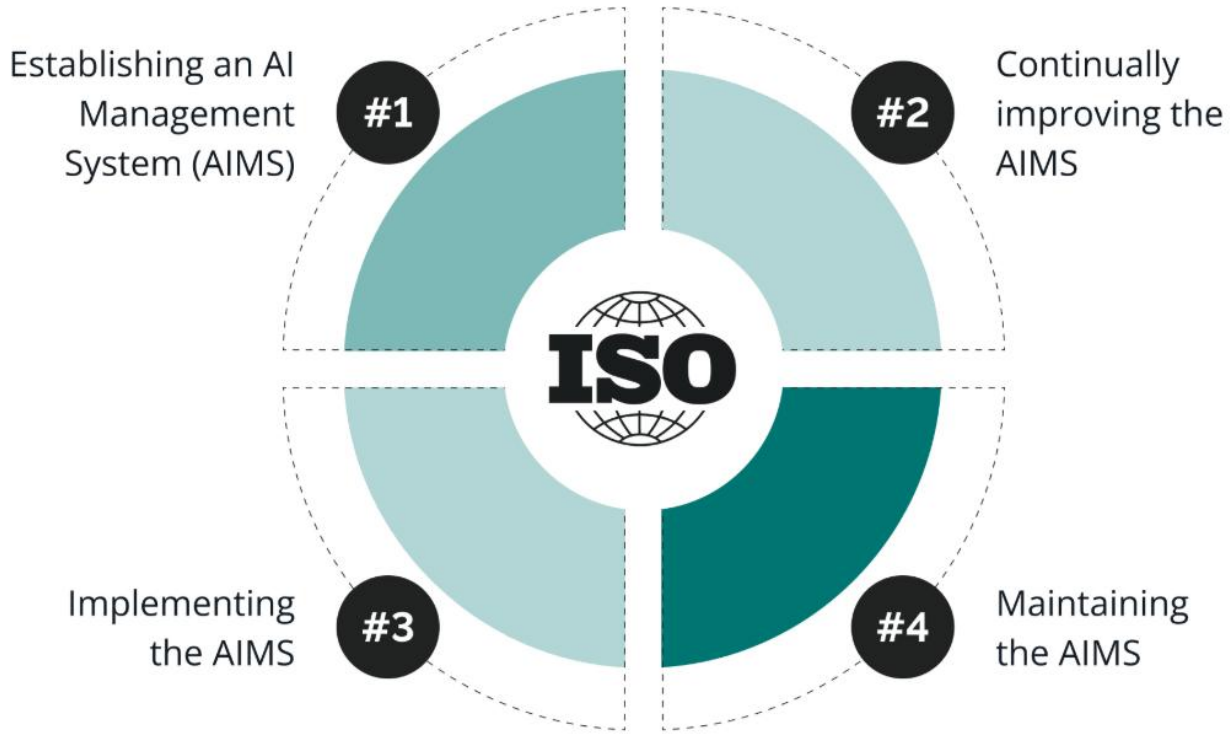

Figure 2: ISO/IEC 42001 – AI Management System Standard process (International Organization for Standardization, 2023)

2.3.3 NIST AI Risk Management Framework (AI RMF)

NIST AI RMF (2023) provides an international standard for an AI risk management framework that is based on four basic concepts: map, measure, manage, and govern, as shown in the diagram (Figure 3). This is the main framework that most of the companies are using to mitigate, measure, or monitor risks in AI infrastructure (National Institute of Standards and Technology [NIST], 2023). But when we talk about small and medium organizations, the required flexibility due to their complexity level and ease of implementation makes it difficult for rely on NIST AI RMF.

Figure 3: NIST ARMF (National Institute of Standards and Technology [NIST], 2023)

However, the NIST AI risk management framework provides excellent work guidelines and standards for managing AI risks, but its adaptations in small and medium organizations are limited due to the limited resources and lack of clear implementation guidelines (Sarker et al., 2025).

2.3.4 ENISA AI cybersecurity guidelines

The European Union Agency for Cybersecurity (ENISA) is the main resource of guidelines where organizations get ideas and directions to address AI cybersecurity risk, which focuses on AI data protection, model integrity, and secure development and deployment (ENISA, 2023). ENISA has already published many reports and guidelines to help organizations to secure their infrastructure and protect from AI threats, and recommends security from design to deployment, ensuring the regular review and testing of AI systems.

These guidelines align with the upcoming EU AI Act, emphasizing compliance and accountability. However, ENISA's recommendations often assume institutional capacity, which smaller organizations may lack (Sotamaa et al., 2023).

2.3.5 European Union Artificial Intelligence Act

The European Union has advanced the first comprehensive regulatory instrument for AI, commonly referred to as the EU AI Act (European Union, 2024). The Act adopts a risk-based approach that categorizes AI systems into prohibited, high-risk, and low/minimal-risk tiers and sets out specific obligations for high-risk systems (data governance, documentation, human oversight, robustness, and post-market monitoring). The EU AI Act introduces enforceable legal obligations across the EU internal market and thus significantly raises the compliance requirements for organizations operating in Europe. For SMEs, the Act presents both compliance burdens and opportunities for market differentiation through certified trustworthy AI practices.

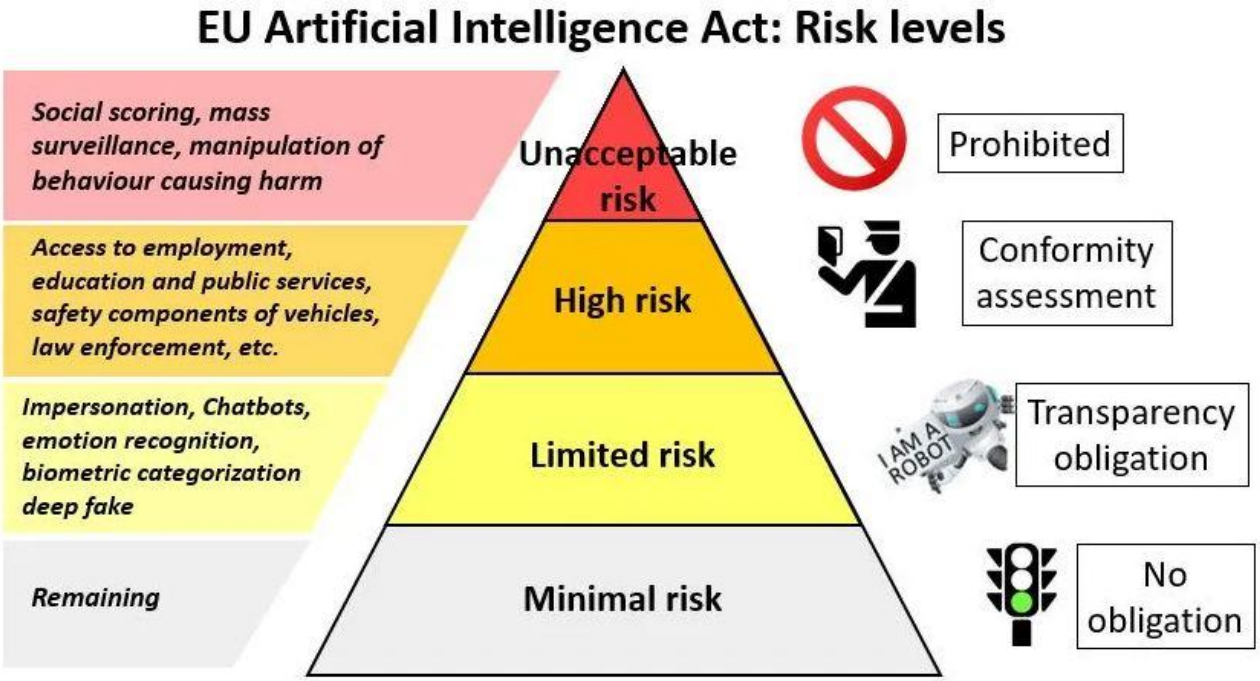

Figure 4: EU AI Act (EU's Artificial Intelligence (AI) Act - Civilsdaily, 2023)

2.3.6 OECD and AI ethics guidelines

The Organisation for Economic Co-operation and Development (OECD) published the OECD AI Principles, a set of high-level policy recommendations promoting human-centered AI that respects human rights, fairness, transparency, robustness, and accountability (OECD, 2019). These principles have been widely referenced by national strategies and inform both standardization efforts and corporate AI ethics programs. Related ethical guidance from the European High-Level Expert Group (AI HLEG) and UNESCO amplify similar norms and operationalize them into organizational practice guidance (AI HLEG, 2019).

2.3.7 IEEE and sectoral standards

The IEEE 7000 series and other technical working groups have produced standards and recommended practices addressing algorithmic bias, explainability, and socio-technical impacts. While often more technical and specialized, these efforts contribute to an ecosystem of normative guidance that informs model validation methods, transparency mechanisms, and ethical assessments.

2.3.8 Other relevant frameworks and research models

There are several academic research works that have already been done by security researchers on the domain of AI risk. For example, Žigienė et al. (2019) proposed a risk management framework focused on AI domain for small and medium companies' risk management process. Zeijlemaker et al. (2025) also focus on how AI systems transform our traditional cyber risk management.

However, most of the frameworks are still based on theoretical understandings, and there are no practical application guidelines for small and medium companies with limited cybersecurity resources and workforce.

A security risk management landscape is beyond the international standards; there are many standards that have been developed by industries, national bodies and academic institutions, and private organizations. These standards and guidelines provide specialized tools, comprehensive coverage, and an approach by the sector wise that is all over the entire ecosystem of AI governance. So, it is mandatory to understand these additional resources and standards as curricular to develop a comprehensive framework that addresses multi multi-nature of AI security risk management.

Industry and consortium frameworks

- **OWASP AI security and privacy guide:** The Open Web Application Security Project is well known for web application security, and has introduced "AI Security and Privacy Guide" (OWASP, 2023a). This is also part of the top ten machine learning projects that focus on the most critical security risk in machine learning, and also guides the practitioner and provides guidelines. It provides the top 10 threads for machine learning, such as "ML01: Prompt Injection," "ML02: Insecure Output Handling," and "ML03: Training Data Poisoning," and also provides prevention strategies and attack scenarios of each risk. This

guide provides help to the technical team members to make them familiar with the top 10 risks of application security. Although this guide provides the overall view of technical risk analysis and mitigations but it's lacking on the governance side, which misses a comprehensive management framework. The lack of structured governance components and continuous improvement cycles in the organization's process makes it an incompatible solution, because it is mandatory to integrate organizational-wide risk assessment, particularly for SMEs, which provides an overall view of the organization instead of technical controls (Sobers, 2023).

- **MITRE ATLAS™ (Adversarial Threat Landscape for Artificial-Intelligence Systems):** MITRE provides attack frameworks for cybersecurity. It also developed a framework for AI Security named ATLAS (Adversarial Threat Landscape for Artificial-Intelligence Systems). The main purpose of this framework is to provide a structured matrix that includes adversary goals and techniques, such as "Data Poisoning" and "Model Evasion," that also include mitigation guidelines. This framework provides the attacker's view to understand how attackers can compromise AI systems by using threat modelling and intelligence techniques. It provides integration with existing cybersecurity operations with the broader ATT&CK ecosystem. Although ATLAS provides a threat landscape for AI Systems to understand how attackers can compromise AI pipelines but does not provide how an organization should apply governance, management, and risk assessments. SMEs require overall risk management for the AI Systems, not only for the technical threat landscape that ATLAS provides (Stokes, 2022).

Corporate and vendor-specific frameworks

- **IBM's AI governance suite:** A multidimensional AI security framework established by IBM that covers a comprehensive suite of AI governance tools. It provides algorithms and metrics that detect and mitigate risks in the machine learning models and offers techniques for improving model transparency and interoperability (Bellamy et al., 2019). This integrate tools for the broader AI Governance framework that provide particular attention to data tracking, model monitoring and end to end AI lifecycle management with automated bias detection. This framework is not flexible in sense of SMEs needs and requirements.

- **Microsoft's responsible AI standard and toolchain:** Microsoft also introduced AI principles through the "Responsible AI Standard" (Microsoft, 2022), which only focuses on developing

AI systems securely and provides information and guidelines to the engineers who develop the AI systems. This is a collection of software suites and open source tools that improve fairness, model explainability, and model error distributions. It also combines main components, including policies, processes, and practical training tools for governance within large enterprises. Although it's applicable to small and medium enterprises, but also part of the problems and creates constraints due to several factors. First, tools are integrated with Microsoft Azure cloud platforms and development ecosystems. Second, the governance models require dedicated roles and extensive review boards, which may often be unfamiliar to smaller organizations. So due to these problems, Microsoft a security standards and toolchains may not help the smaller and medium enterprises due to its constraints (Smith, 2023).

- **Google's AI principles and perspective on AI risk management:** Google introduced AI Principles (Google, 2018) and a detailed "Perspective on AI Risk Management" (Google, 2023). The document mentioned risk risk-based life cycle approach that focuses on safety robustness and security testing, including red teaming of AI models, fairness assessment and privacy techniques. Google also introduced tools and research, such as the TensorFlow library and papers on robustness. The framework focuses on cutting-edge research and an engineering technical perspective for securing AI systems. But, for SMEs primary challenge is the highly technical barriers and limited resources. The implementation of the Google recommended practice may require a lot of technical expertise and resources which is not suitable for small and medium enterprises (Bender, 2021).

National and sectoral initiatives

- **Singapore's model AI governance framework (MGF):** A framework was developed by the Infocom Media Development Authority (IMDA) and the Personal Data Protection Commission (PDPC). Singapore's MGF (IMDA & PDPC, 2020, 2022) is an example of AI governance implementation on the national level. The second edition consists of the details of sector-oriented implementation guidelines by self-assessment, checklist, and case studies. It provide explainability and transparency by using practical methods for achieving these goals. This framework is well known for its practical implementation, making it more accessible than other ISO standards. However, due to a national framework, this mainly focuses

on Singapore's regulatory authority's strategic goals. But the SMEs from all around the world, mostly in the EU, recommended the GDPR and EU AI Act, which may help to SMS but will lack in compliance and regulatory requirements. The plus point is that it also focuses on comprehensive technical security, threat governance, and consumer protection (Tan, 2023).

- **UK ICO's AI and data protection risk toolkit:** The UK Information Commissioner's Office (ICO), the data protection regulator, introduced a dedicated "AI and Data Protection Risk Toolkit" (ICO, 2022). This toolkit is designed to help organizations by using questionnaire-based tools and an interactive way to ensure that AI complies with the data protection law (UK GDPR). It helps organizations by assessing lawfulness, fairness, transparency, and accountability in their AI projects and provides a direct link to legal compliance. Its user-friendly guided format Is the major strength of this framework. Although this toolkit provides data protection risk very super way but the full spectrum of security risk is not a complete way to assess AI security risk management of the organization (Wachter, 2021).

Academic and research-oriented models

- **The "Socio-Technical AI Risk Assessment" (STAR-AI) model:** Proposed by Kraus et al. (2021), this framework mainly explains that AI security risk can not only be assessed through technical assessment. This academic STAR-AI model framework explains that the overall evaluation of AI models consists of four dimensions: technical, data, human, and organization. Technical assessment consists of model performance and robustness, while data assessment consists of quality storage and lineage of data, and humans include trust, fairness, and ethical issues. This study provides structured theoretical guidelines that cover four dimensions instead of practical implementation. This conceptual and assessment methodology lacks in-depth implementation guides and tools that are required for SMEs.
- **"Securing Machine Learning" (SecML) research streams:** A substantial body of academic research, synthesized in works like "*SoK: Security and Privacy in Machine Learning*" (Papernot et al., 2018) and advanced by labs such as the CleverHans project (Goodfellow et al., 2020), mainly focuses on theoretical applications and the foundation of AI security systems, and provides scientific understanding of threats. It also develops and assesses the defense algorithms. However, this research focuses on the technical aspects of AI security

risks that may require advanced expertise in machine learning and cybersecurity. It produces algorithms and benchmarks as an output, not required by enterprises to implement. SMEs may get advantages from this research indirectly, but for direct use, it is lacking in different components of AI security risk management concepts (Carlini, 2021).

- **The "SME-TEAM" (Trustworthy and Ethical AI Management) model:** A research-focused SMEs context, Sarker et al. (2025) introduced the SME-TEAM model. This security model focuses on trust and ethics to enable organizations for security and compliance, instead of separate burdens. This model provides the assessment of ethical impact, transparency, and accountability by focusing on SMEs, which is based on finding the operational issues of ethics in AI management. However, this model explains AI security risk management and ethical issues in small and medium enterprises and focuses on the governance part, but offers fewer details in the identify, assess, and strengthen functions. It means that it only pays attention to governance and ethical management, but for technical assessment, it lacks the requirement of SMS in the whole process of the AI security risk management system.

Sector-specific frameworks

- **Financial services AI security framework:** A consortium of financial institutions developed a Financial Services AI Security Framework (FS-AISF), that focuses on the unique requirements of the financial sector (FSB, 2023). This framework provides compliance with the regulatory requirements specifically in finance that include high-stakes decision making, real-time security requirements for trading and transaction systems and also includes third-party risk assessments for AI service providers. This framework includes the controls that are specifically designed for financial regulations and includes response protocols for all security incidents. Due to the sector-specific nature, this framework is limited abilities and does not fulfill SMEs' requirements, which also focus on other industries.

- **Healthcare AI security and safety framework**: The framework that focuses on healthcare infrastructure, particularly medical applications, which consists of patient safety considerations in AI system design, data privacy requirements, clinical validation verification process, and regulatory compliance with medical devices regulations (FDA, 2022). This framework provides the safety and security for clinical systems to protect critical health-related data of patients. So, due to health-specific requirements, these frameworks are proficient for

the safety and security of AI in medical systems, but in other domains, they may not be valuable.

2.4 Challenges for SMEs and startups

There are several challenges SMEs face due to their limited resources and lack of technical expertise for AI security risk management. Common challenges include:

- Limited financial resources and a lack of expertise and staff to implement comprehensive security tools.
- Supply chain issue due to the dependencies on 3rd party vendors.
- Lack of technical expertise, often due to absent security roles, can lead lack of governance and risk awareness (Sotamaa et al., 2023).

Moreover, there is a high trend in SMEs to adopt AI to compete with the market, but often they adopt without the implementation of controls for data governance due to limited resources, which can lead to AI threats. This incompatibility between innovation and security can cause security and compliance issues under the EU AI Act (Somer & Thalmann, 2023).

Therefore, development of a lightweight, easy to adopt, deploy, scalable, and affordable AI security risk management framework is essential to support small and medium enterprises to use and take benefits from AI while maintaining their security and compliance.

2.5 Research gap and conceptual basis for the framework

After the study of existing air security frameworks, we realize that the existing frameworks are complex, generalized, and require a lot of resources in terms of financial budget as well as technical experts. While the existing frameworks have valuable guidelines and standards, they are not suitable for SMEs due to a lack of a cybersecurity expert team or financial abilities. Additionally, some studies focus on cross frameworks to build a single unified approach to meet small and medium enterprises' requirements and needs (Sarker et al., 2025).

This gap defines the importance of a new AI risk management framework that will be fully compatible with small and medium-sized companies, including startups, and will combine the essential

elements from ISO, NIST, and ENISA standards, which will be scalable, lightweight, can be easy to adopt their AI security controls without any security experts or extra financial resources.

3 Methodology

The chapter explains the methodology used for the development of an AI security risk management framework for small and medium-sized enterprises and startups. It also explains the research design, data collection methods, and data analysis and validation approach to ensure reliability and academic research. This methodology approach focuses on qualitative and literature-based studies that focus on structured analysis of existing security risk frameworks, such as ISO/IEC 42001, ISO/IEC 27005, the NIST AI RMF, and ENISA guidelines.

3.1 Research design

This study focuses on a qualitative research design by using a literature review and framework synthesis. There is no collection of raw numerical data, but the main objective is to identify the essential components of existing frameworks, guidelines, and standards to consolidate knowledge into a proposed new security risk management framework designed specifically for SMEs.

For this research, qualitative research is more appropriate than quantitative because it fully explains the complex concepts, such as risk management and AI governance, that are not easily quantifiable (Creswell & Creswell, 2018). This thesis research integrates deductive reasoning based on established theories and standards to build a new framework suitable for small and medium-sized organizations with limited resources.

3.2 Research approach

This study focuses on a qualitative research approach based on exploration, understanding, and interpretation rather than numerical measurement of the data. The main goal is to develop an AI security risk management framework based on the needs of small and medium-sized enterprises and startups.

This qualitative approach includes the following stages:

- **Problem identification:** Finding gaps in existing frameworks and standards, and the lack of suitability of AI risk management for SMEs and startups.
- **Objective definition:** Designing a simplified, adaptable, and cost-effective AI Security Risk Management Framework (AIS-RMF) to enhance security and risk governance in AI-driven environments.
- **Data collection and analysis:** Comprehensive literature review of existing frameworks, standards, and studies on AI security risk management, and analyzing information thematically to find essential components and principles best suited for small and medium organizations
- **Framework development:** Synthesizing the essential components into a lightweight, affordable AI risk management framework to meet the needs of small and medium organizations, including startups with limited technical and financial resources.
- **Evaluation:** The proposed AI risk management framework will be evaluated based on conceptual evaluation, literature-based validations, expert insights, as well as hypothetical application scenarios.

This approach ensures that the resulting framework is both theoretically grounded.

3.3 Data collection method

3.3.1 Literature review

A comprehensive systematic literature review (SLR) is the main data source for this study, and I have gathered data from a lot of resources from the Internet, Google Scholar and IEEE Explorer. Mostly, I got the data from existing frameworks, industry reports, as well as regulations and compliance guidelines.

The inclusion criteria were:

- Publications, journals, frameworks, standards, and guidelines addressing AI security risk management and governance.
- Studies and standards that focus on SMEs and are applicable to small organizations
- Frameworks such as ISO/IEC 27005, ISO/IEC 42001, NIST AI RMF, and ENISA AI cybersecurity guidelines.

- Exclusion criteria included outdated studies (before 2018), non-peer-reviewed blogs, and documents lacking methodological rigor.
- Outdated studies are included as exclusion criteria, and non-peer-reviewed blogs and documents.

3.4 Data analysis

International standards, frameworks, and guidelines were analyzed on the basis of identified gaps and the growing need of small enterprises in AI risk management. After analyzing the unique components extracted on the basis of requirements and needs.

The comparative analysis focused on:

- Scope (AI-specific risk management).
- Focus on SMEs and startups.
- Complexity and resource requirements.
- Integration potential into a unified SME-oriented model.
- These insights guided the design of the new AI-SRMF.

3.5 Validity and reliability

Since that research is totally based on literature review and we can validate our research by finding the data from reputable and peer-reviewed resources, and we can ensure that the data gathered from official standards and the government, and institutional publications.

By maintaining a transparent and replicable review procedure, viability was supported in this research, and documenting databases search strings and analysis steps is included in this process.

3.6 Ethical considerations

This study adheres to academic research ethics as outlined by JAMK University of Applied Sciences. No human participants or personal data were involved in the primary research phase. Intellectual property from frameworks and standards has been properly referenced, and secondary sources have been cited according to APA 7th edition.

4 Proposed Framework

4.1 Framework core

The proposed AI risk management framework core provides a high-level view of the framework that includes four functions, as shown in Figure 4. These core functions are Governance, identify, assess, and strengthen. Each of these high-level functions is broken down into categories, and these categories are also expanded into subcategories, and each subcategory have lists of instructions that provide guidance to the users. It works on iterations that start from identification, assessment, and strengthening, then start again with identification, and governance plays the base role in all these three functions that take place at any time of the life cycle.

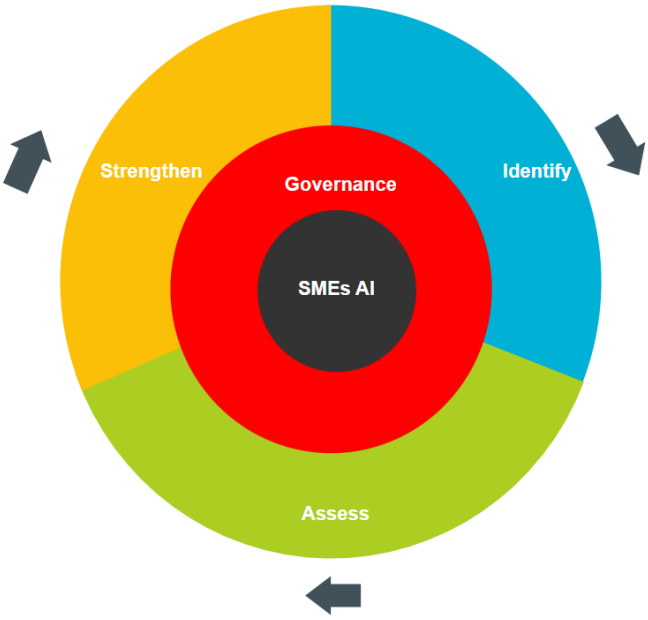

Figure 5: AIS-RMF (AI Security Risk Management Framework)

The core functions are:

1. **Governance:** Establish governance, policies, and accountability for AI risk.

2. **Identify:** Discover AI assets, data, and potential threats.
3. **Assess:** Evaluate and prioritize AI-related risks.
4. **Strengthen:** Implement mitigation controls, monitor effectiveness, and improve resilience.

Governance is the main function that continues at any stage of the AI life cycle, which provides strategies and vision that is set by top management to implement AI security. “Identify” function that holds a list of categories and subcategories that contain information and instructions to list out the AI inventory and find out assets, stakeholders, and potential threats for the AI systems. After the identification of AI assets and threats, the next process is the assessment function. In the assessment function, measure and assess the impact of the threats on our business. After the evaluation and assessment of each thread, prioritize threats as per their impact. This strength function is the last part of the life cycle of AI risk management that ensures how to tackle the identified and assessed threats. It covers all the instructions that are needed to take place to handle the identified and assessed threats.

The framework aligns with NIST AI RMF (2023), ISO/IEC 27005:2022, ISO/IEC 42001:2023, ENISA AI Cybersecurity Guidelines (2023), and the EU AI Act (2024).

4.2 Function 1: Governance

Governance is the foundational layer of the AIS management framework that provides organizational context, leadership, and accountability that are necessary for managing AI risks. It also ensures that all AI activities are under a structured framework that holds trust, transparency, and compliance. Governance is the collective process of achieving the organizational values and ethical standards that align with AI standards and guidelines; it's not only an administrative process but also contributes leadership as well as employees in this process.

In practice, governance establishes the vision and mission for a responsible AI system in the organization, it works with leadership to explain the objectives of AI use and set the rules of these objectives within the company’s mission. The purpose of governance is to contribute to AI initiatives in organizational goals while providing a safe environment for individuals, societies, and businesses themselves.

Governance is the continuous process that involves monitoring, evaluation, and improvement of the AI risk in organizations. It's not a static process and regularly reviews the coordinate structure to assess that it's working effectively and updates the policies as per the response. The ongoing process of governance ensures that it remains relevant and works according to the requirements and needs. Leadership plays a very important role in the continuous improvement of governance and fostering a culture of enforcement of AI ethics and risk awareness.

The **Governance function** (Table 2) establishes a baseline for secure, ethical, and reliable AI systems in small and medium-sized enterprises. It primarily focuses on

1. Clearly define roles and responsibilities under the leadership and accountability method in AI operations.
2. Maintain regulatory and compliance requirements with the relevant standards and laws.
3. Ethical considerations to manage the use of AI, including fairness, transparency, and human oversight.
4. Strategic risk alignment with business objective animations.

This function is crucial for SMEs because, unlike large organizations, they have **limited resources**, making **lightweight but structured governance** essential.

Sources: NIST AI RMF §Govern 1.1–2.5; ISO/IEC 42001 §4–6; ISO 31000 §5–6; ISO/IEC 27001 Annex A; ENISA AI Guidelines §2; EU AI Act §9–13.

Table 2: Function 1 - Governance

Category	Description
1. Governance & Leadership	**1.1. AI Governance Structure:** Create a structured standard and rules that define AI security, ethics, and privacy, and cover leadership, IT, and data management (NIST AI RMF §Govern 1.1; ISO/IEC 42001 §5.3). **1.2. Roles, Responsibilities, and Accountability:** When it comes to the life cycle of AI, design, training, deployment, and monitoring are the four main stages, and

		assigning specific roles to individuals is critical to their success, using a RACI matrix. Responsible, accountable, consulted, and informed, to ensure that everyone is clear on what they are supposed to do (ISO/IEC 27001 Annex A §A.5.1; ENISA §2.1). **1.3. Governance Charter:** The Governance Charter, then, is basically a document that states our group's purpose, its guiding principles, and how we secure and ethically sound AI decisions (ISO 31000 §5.2; NIST AI RMF §Govern 1.2). **1.4. Stakeholder Engagement & Oversight:** List out all internal and external stakeholders and establish communications regarding AI risk and ethical issues (ISO/IEC 42001 §5.4; ENISA §2.2). **1.5. Transparency & Auditability:** Take care of all the records related to a model's data usage and decision logic for compliance with audit and regulatory inquiries (EU AI Act §Art. 12; NIST AI RMF §Govern 1.4)
2.	**Regulatory & Ethical Compliance**	**2.1. Regulatory & Legal Mapping:** Find out all the required documents and information regarding relevant rules and standards that apply to AI operations, including GDPR, EU AI Act, ISO/IEC 42001, and national cybersecurity regulations (EU AI Act §9–10; ISO/IEC 42001 §4.1). **2.2. Ethical AI Principles & Code of Conduct:** Make and enforce organizational policies related to fairness, explainability, human oversight, and inclusivity. Publish an AI ethics statement (OECD AI Principles 2019; NIST AI RMF §Govern 2.3). **2.3. Transparency & Explainability Standards:** Perform documentation for AI models and the decision-making process to ensure transparency and explainability for stakeholders (EU AI Act §Art. 13; ENISA §2.3). **2.4. Compliance Monitoring & Internal Audits:** Make a schedule for periodic internal audits and compliance checks. Maintain records of all findings and track remediations to align with policies (ISO/IEC 42001 §9.2; ISO/IEC 27001 §A.9.1). **2.5. Responsible AI Communication:** Make sure all the information shared with users whenever interacting with an AI system, and also explain limitations, capabilities, and intended purposes (EU AI Act §Art. 52; ISO/IEC 42001 §8.3).

3.	**Risk Context & Strategy**	**3.1. Define AI Risk Context:** Explain all the factors including internal and external, that can have an impact on AI infrastructure, containing the technology dependencies, data types, and evolving threat landscape (ISO/IEC 27005 §6.1; ISO 31000 §5.3) **3.2. Define AI Risk Appetite & Tolerance:** Define the level of acceptable risk that organizations can tolerate and explain the value of risk where organizations can afford risk impacts (ISO 31000 §6.3; NIST AI RMF §Govern 2.2). **3.3. Risk Communication & Escalation Channels:** Explain the reporting process related to internal escalations and AI security and issues **(**ISO/IEC 42001 §7.4). **3.4. Risk Management alignment with Business Objectives:** Make sure AI risk assessment is working on behalf of the business strategy while maintaining ethical values (NIST AI RMF §Govern 2.5; ISO/IEC 27005 §6.4). **3.5. External Stakeholder Coordination:** Make policies for sharing with external bodies such as suppliers, clients, and partners to coordinate AI risk responses(ENISA §3.2; ISO/IEC 27036-3 §7).

4.3 Function 2 – Identify:

Identify function is the main backbone function of the AI security risk management framework (AIS-RMF) that enables organizations to understand the AI ecosystem. It focuses on the identification of the assets that the organization is using, including data dependencies, stakeholders, and external factors that can influence AI in the organization. It covers all stages of the AI lifecycle, like development, deployment, and operation of AI systems. In SMEs, it plays a very important role to find out the main understanding of the AI system, where and how AI is used, and what dependencies, threats, or risks are from its use.

Identify function, starts with the finding of tangible and intangible elements of AI assets that influence and support AI operations, which include machine learning models, algorithms, data sets, API, and third-party components such as pre-trained models or cloud-based AI services. By collecting all this information, SMEs establish an inventory of AI assets that help in accountability and the foundation of the risk management process. This inventory promotes transparency and accountability by sharing information with decision makers.

Another important part of this function is to identify the AI system dependencies, interface, and external elements, which include libraries, frameworks, API's and third-party services that may cause supply chain risk and vulnerabilities. Mapping of these dependencies makes their associated risks visible, enabling SMEs to evaluate supplier reliability, data frequency, and security assurance. This mapping helps to prevent unintentional exposure to the risk.

This function also explains the identification of stakeholders and their roles in the AI life cycle. It includes the identification process of internal and external stakeholders. Internal stakeholders include developers, data scientists, IT administrators, managers, and owners, and the external stakeholders may include customers, partners, regulators, and users. Understanding and identifying these stakeholders helps in the accountability and governance process within the AI ecosystem.

After the identification of stakeholders and assets, the next process in this function is to find the threats and contextual risk analyses. This process involves the identification of technical and non-technical AI-specific risks such as data poisoning, model inversion, adversarial attacks, and algorithmic bias. SMEs can focus on the identification of threats and priorities later on for risk assessment.

Table 3 maps the technical threats related to machine learning and categorizes these threats into confidentiality, integrity, and availability (CIA). This mapping of threats covering the CIA gives an overall view of security and related threats.

Table 3: Machine learning Threats

Threats Details			Threats	
			Machine learning Threats	Other Threats
Integrity or availability threats	System malfunctions	Due to the unintended behavior of machine learning elements	Data poisoning attacks	Traditional attacks against software and hardware
			Model poisoning attack	
			Misuse of pollution models	
		Due to other factors		Traditional attacks against systems

	Waste of computational resources	Due to machine learning elements	Data poisoning attack for resource depletion	Traditional attacks against software and hardware
			Model poisoning attack for resource depletion	
			Misuse of pollution models	
			Sponge attack	
		Due to other factors		Tradational attacks agains systems
Confidentiality threats	Leakage of information about AI models		Model extraction attacks	Tradational attacks for stealing AI models
	Leakage of sensitive information of training data		Information leakage attack	Tradational attacks that steal data
			Data poisoning attack for information leakage	
	Leakage of other confidential data		Model poisoning attack for information leakage	

Traceability and documentation are also important parts of this function. SMEs can use documentation to register AI asserts and record details about each system. This documentation helps the organization to trace the assets and provide the facility of internal coordination, and also, it's helpful for external compliance and audit, particularly under ISO/IEC 42001 and the EU AI Act, which shows the importance of transparency and accountability.

This function is specially designed for small and medium enterprises to be scalable and resource-efficient. It doesn't require expensive tools or very expert and large team members to manage or identify the assets, stakeholders, and records. Most of the activities under these functions can be handled with a single staff member, as well as simple documentation templates and spreadsheets. This function focuses on mapping of all systems, regardless of size or complexity in a very systematic way.

So, identify the function (Table 4), explain the inventory of AI assets, potential threats, data flows, and stakeholders within the AI environment. This function ensures that the organization can visualize its AI infrastructure and understand and detect threats and vulnerabilities at early stages.

Key objectives of this function:

1. Make an inventory of all AI assets, including models, datasets, APIs, and infrastructure.

2. Maintain documentation for data flow and dependencies for risk exposure and assessment.
3. Identify unique threads, including operational and ethical risk.
4. Prioritizing the identified risk as per the business objective and needs.

Sources: NIST AI RMF §Identify 2.1–2.5; ISO/IEC 27005 §8; ISO/IEC 42001 §8; ENISA AI Threat Landscape §3; MITRE ATLAS; EU AI Act §9–13.

Table 4: Function 2 - Identify

Category	Description (Heading with Sources)
1. AI Asset Inventory	**1.1. System & Model Identification**: Maintain a record of all AI systems, models, software components, and data (ISO/IEC 42001 §8.1; NIST AI RMF §3.1). **1.2. Stakeholder Identification:** List out all stakeholders, including external and internal, that are accountable for all AI assets (ISO/IEC 42001 §8.2; ENISA §5.1). **1.3. Infrastructure Mapping**: Create a list of all computational resources, including servers, systems, cloud services, storage, and IT infrastructure (ISO/IEC 27005 §8.1; NIST AI RMF §3.1).
2. Data Mapping & Classification	**2.1. Dataset Inventory**: For training, validation, and testing, list out all data sets that include information on the source, sensitivity, and the use of the data (ISO/IEC 42001 §8.2; NIST AI RMF §3.1). **2.2. Data Quality & Lineage**: Track data performance, preprocessing steps, transformations, and version control to ensure traceability (ISO/IEC 27005 §7.3; ENISA §5.2). **2.3. Privacy & Regulatory Sensitivity:** Classify datasets according to legal and regulatory requirements (e.g., GDPR, EU AI Act) and internal policies (EU AI Act §9–10; ISO/IEC 27001 §A.18.1). **2.4. Assumptions & Constraints:** Document all the assumptions that may impact on risk validity that such as environmental, technical, and operational (ENISA §5.1).
3. Threat Identification	**3.1. Technical Threats**: Identify all technical-related threats using pen testing and ethical hacking techniques to find out the vulnerabilities and other threats (NIST AI RMF §3.2; MITRE ATLAS; ENISA §5.3). **3.2. Data Threats**: Identify all the threats that focus on data, which covers all the stages of data, such as data in use, data at rest, and data in transit (ISO/IEC 27005 §7.3; GDPR Art. 5).

		3.3. Operational Threats: Identify all operational threats that can impact AI systems, such as human errors, configuration weaknesses, and process failures (ISO/IEC 27005 §7.4; ENISA §5.1).
4.	**Ethical and Governance Risks**	**4.1. Bias & Fairness**: Identify and analyze the output of AI systems based on fairness across the protected attributes and identify unfair decision-making (NIST AI RMF §3.3; EU AI Act Art. 10). **4.2. Transparency & Accountability**: Identify the weaknesses in the documentation and also gaps in transparency and accountability (ISO/IEC 42001 §8.4; ENISA §5.4). **4.3. Regulatory & Policy Gaps:** Identify the gaps in the governance process and lack of regulatory implications and audits (EU AI Act §9–13; ISO/IEC 42001 §8.3).
5.	**Third-Party & Supply Chain Risks**	**5.1. Dependency Mapping:** Identify all the components that belong to all AI external components, such as libraries, API, and services (ISO/IEC 27036-3; NIST CSF ID.SC). **5.2. Third-Party Threat Assessment**: Evaluate and analyze the AI security risk that belongs to external contributors, such as suppliers and vendors (ENISA §5.2; ISO/IEC 27005 §8.2). **5.3. Contractual & Compliance Review:** Analyze the agreement that belongs to third parties, which includes the assessment of security, privacy, and regulatory (ISO/IEC 42001 §8.3; EU AI Act §12).
6.	**Documentation & Traceability**	**6.1. Asset & Risk Register**: Maintain a centralized record system that is easy to traceable, which includes the information on data, AI assets, threats, and associated risks (ISO/IEC 42001 §8.1; NIST AI RMF §3.1). **6.2. Mapping Reports**: Generate reports related to AI threats that provide the summarized information of AI assets and risk exposures (ISO/IEC 27005 §8.4; ENISA §5.5). **6.3. SME-Friendly Tracking:** Make sure all the records are easy to trace with open-source tools and use spreadsheets to manage the records and ensure that the records is traceable and manageable without any technical or financial requirements (ISO/IEC 42001 §8.5; NIST AI RMF §3.1).

Implementation guidance for SMEs

- Use simple spreadsheets or lightweight asset management tools for AI systems, datasets, and dependencies.
- Update the asset and threat register quarterly or after major system changes.

- Map threats to technical, operational, and ethical controls for downstream risk assessment.
- Maintain documentation aligned with GDPR and EU AI Act requirements.
- Assign clear stakeholder responsibility for each AI asset or dataset.

Expected outcomes

1. **Complete inventory** of AI assets, datasets, and dependencies.
2. **Comprehensive threat map** including technical, operational, ethical, and third-party risks.
3. **Traceable documentation** for audits, governance, and regulatory compliance.
4. **Lightweight and practical process** suitable for SMEs and scalable for growth.

4.4 Function 3 – Assess:

Assess function mainly focuses on the analytical evaluation of the identified threats, AI assets, and data sources, and assesses their risk level based on likelihood and impact. Using this function, SMEs analyze the identified threats and fill the gaps between risk identification and risk treatment and facilitate the decision makers to take actions after the evaluation of identified threats.

In the beginning stage of this function, focus on the risk assessment process, which follows general principles of ISO/IEC 27005:2022 and ISO 31000:2018. It contains basically 3 iterative stages: risk analysis, risk evaluation, and risk prioritization

4.4.1 Risk analysis:

The risk analysis phase of SMEs tries to evaluate and analyze the risk on the basis of likelihood and impact. Likelihood is the probability of the threat occurring, and impact is the potential consequences of the risk executed. This analysis covers multiple dimensions, including:

- **Technical risks**: Covers the analysis of threats in technology used in AI systems, such as machine learning threats that include model poisoning, adversarial attacks, or software vulnerabilities.

- **Data-related risks**: Focus on data that is used in AI systems, including data bias, data leakage, or privacy breaches.
- **Operational risks:** Analyses of operational activity, including inadequate AI maintenance, lack of model explainability, or system downtime.
- **Ethical and societal risks**: Analyses that focus on societal ethics such as discrimination, transparency violations, or user mistrust.

In practice, SMEs can use a risk matrix to classify risks into low, medium, high, and critical levels. This helps organizations in the prioritization process for mitigations.

4.4.2 Risk evaluation:

After analysis of the risk, the next process is to evaluate the risk as per the organizational objective needs and legal requirements, as well as stakeholder expectations. This ensures that AI is associated with the business environment. This process helps to determine the risk acceptability and also specifies the tolerance of the risk, and a risk that requires immediate mitigation.

4.4.3 Risk quantification

In this process, the identified risks involve translating qualitative assessment into a measurable scale for prioritization and comparison. SMEs can adopt this method by using semi semi-quantitative approach using a scoring system like a 1 to 5 scale, which means 1 is the lowest level and 5 is the highest level, so by using this method, SMEs can quantify their risk prioritization, which facilitates ranking and reporting.

SMEs can use simple spreadsheets or templates to measure and assess the risk and gradually increase level by using more sophisticated tracking systems. This modular approach shows scalability without unnecessary resources or complexity.

4.4.4 Outcome and alignment

The outcome of this measure function is it comprehensive and prioritized AI risk profile based on the evaluation that helps further make decisions in the next strengthening function.

So, Table 5 shows all instructions of the access function that help to analyze, assess, and quantify AI risks that are identified in the previous “Identify” function. For SMEs, this function plays a critical role in analyzing each risk based on organizational objectives and prioritizing these risks as per available resources.

Key objectives of this function:

1. Assess AI risks based on likelihood and impact across technical, operational, and ethical dimensions.
2. Convert the assessment of AI risk into measurable scales and quantify risk level to take further decisions.
3. Prioritize the risk based on severity, criticality, and or organizational resource capacity.
4. Ensure assessments meet regulatory and ethical requirements that ensure transparency.

Sources: NIST AI RMF §Measure 3.1–3.5; ISO/IEC 27005 §8; ISO/IEC 42001 §8; ISO 31000 §6; ENISA AI Threat Landscape §5; EU AI Act §9–13; MITRE ATLAS.

Table 5: Function 3 - Assess

Category	Description (Heading with Sources)
1. Risk Context and Scope Definition	**1.1. Scope Definition:** Define systems, AI models, datasets, and stakeholders to be included in the assessment, ensuring clarity and traceability (ISO/IEC 27005 §8.1; NIST AI RMF §3.1). **1.2. Risk Criteria Establishment:** Set likelihood, impact scales, and SMEs-specific risk acceptance thresholds (ISO/IEC 31000 §6.3). **1.3. AI System Boundary Identification**: Identify functional and technical limits of AI systems, data pipelines, and dependencies (ISO/IEC 42001 §8.1). **1.4. Assumptions and Constraints**: Document environmental, technical, and operational assumptions affecting assessment validity (ENISA §5.1).
2. Risk Identification and Categorization	**2.1. AI System Risks:** Identify model-level threats, including data poisoning, adversarial manipulation, and model inversion (NIST AI RMF §3.2; MITRE ATLAS).

		2.2. Data Risks: Detect privacy breaches, data drift, poor quality, or lack of traceability in datasets (ISO/IEC 27005 §7.3; GDPR Art. 5). **2.3. Ethical and Governance Risks:** Identify bias, unfairness, and lack of transparency in AI outputs or governance structures (NIST AI RMF §3.3; EU AI Act §9–13). **2.4. Third-Party Risks:** Evaluate risks from cloud APIs, external datasets, and open-source libraries (ISO/IEC 27036-3; NIST CSF ID.SC).
3.	**Risk Analysis and Quantification**	**3.1. Likelihood Assessment:** Estimate the probability of each risk using defined scales and expert judgment (ISO/IEC 27005 §8.2; NIST SP 800-30). **3.2. Impact Assessment:** Assess consequences on confidentiality, integrity, availability, ethical performance, and business outcomes (ISO/IEC 27005 §8.3). **3.3. Risk Scoring:** Combine likelihood and impact values to derive overall risk scores, prioritizing higher severity risks (ISO/IEC 31000 §6.4). **3.4. Confidence Level and Uncertainty:** Capture uncertainty, assumptions, and evidence supporting the risk rating (NIST AI RMF §3.3; ENISA §5.2).
4.	**AI Performance, Fairness, and Robustness Evaluation**	**4.1. Performance Metrics Validation:** Analyze the error rates in AI systems using predefined thresholds and datasets and validate AI model accuracy, precision, and recall (ISO/IEC 42001 §8.4; NIST AI RMF §3.4). **4.2. Robustness Testing:** Test AI resilience against adversarial inputs, noise, and perturbations (NIST SP 1270; ENISA §5.3). **4.3. Fairness Assessment:** Evaluate bias across protected attributes to ensure ethical compliance (NIST AI RMF §3.4; EU AI Act Art. 10). **4.4. Explainability and Transparency Validation:** Measure interpretability and clarity of AI decisions to support accountability (ISO/IEC 42001 §8.5; ENISA §5.4).
5.	**Risk Evaluation and Prioritization**	**5.1. Risk Comparison:** Match evaluated risks against SMEs risk appetite and tolerance to determine acceptability (ISO/IEC 31000 §6.5). **5.2. Prioritization Matrix:** Rank risks as High, Medium, or Low to guide resource allocation (ISO/IEC 27005 §8.4). **5.3. Risk Acceptance Decision:** Decide which risks require immediate mitigation versus those tolerable under current controls (ISO/IEC 27005 §8.5; NIST AI RMF §3.5).

	5.4. Reporting and Communication: Summarize evaluation results and communicate them to management, stakeholders, and technical teams (ISO/IEC 42001 §9; ENISA §5.5).

4.5 Function 4 – Strengthen:

This strengthening function is the last part of this iteration that focuses on the mitigation process of the identified risks and takes measures to control and continue monitoring. It also includes all the rules that are implemented to mitigate the identities and how to tackle them if any incidents happen. Table 6 contains information on planning and control implementations, and after that, it measures the effectiveness of the controls that were implemented to mitigate that risk. For SMEs, this function focuses on the controls that are implemented without any high expectations of technical expertise or financial requirements, and integrating best practices from **NIST AI RMF, ISO/IEC 27001, ISO/IEC 42001, ENISA AI Guidelines, and the EU AI Act**.

Key objectives:

1. Implement technical, operational, and organizational controls to mitigate AI risks.
2. Implementation for operational, technical, and ethical AI risks
3. Make sure the implemented controls are working properly and continuously monitor the controls.
4. Comply with the regulatory and legal requirements as per the industry standards.
5. Make sure the immediate response for AI incidents and share the information with relevant stakeholders.

Sources: NIST AI RMF §Enhance 4.1–4.5; ISO/IEC 27001 §A.5–A.18; ISO/IEC 42001 §9–10; ENISA AI Threat Guidelines §6; EU AI Act §14–18.

Table 6: Function 4 - Strength

Category	Description (Heading with Sources)
1. Risk Mitigation Planning	**1.1. Control Strategy Definition:** Explain Technical, operational, and organizational controls and measures for AI systems as per the organization's business objectives and industry standards (ISO/IEC 27001 §A.5–A.18; NIST AI RMF §Enhance 4.1).

		1.2. Mitigation Roadmap: Build a complete roadmap and timeline for implementation of controls that are prioritized based on risk severity and SMEs capacity (ISO 31000 §6.5; ENISA §6.1).
2.	**Control Implementation**	**2.1. Technical Controls:** Implement all technical controls for the protection of AI systems. Well-known controls include access controls, authentication, encryption, anomaly detection, and model monitoring (ISO/IEC 27001 §A.9, A.12; NIST AI RMF §Enhance 4.2). **2.2. Operational Controls:** Implement the process and procedures for secure business operations that include incident handling, patch management, and secure data handling (ISO/IEC 27001 §A.13, A.14; ENISA §6.2). **2.3. Organizational Controls:** Implement all policies related to organizational ethics, staff training, and accountability (ISO/IEC 42001 §9.1; NIST AI RMF §Enhance 4.3).
3.	**Incident Response and Recovery**	**3.1. Detection & Reporting**: Enforce the policy to take actions against any incident as per the criticality of the event, maintain reports, and send to relevant stakeholders (ISO/IEC 27001 §A.16; NIST AI RMF §Enhance 4.4). **3.2. Response Actions:** Maintain a full record of events after forensic analyses of any incidents related to AI systems (ENISA §6.3; ISO/IEC 27035). **3.3. Recovery and Resilience:** Make full-fledged plans for system recovery after any incidents or failures (ISO/IEC 22301 §8; NIST AI RMF §Enhance 4.4).
4.	**Continuous Monitoring and Improvement**	**4.1. Performance Monitoring:** Keep tracking performance and security logging continuously using open-source tools and malicious activity on time (ISO/IEC 42001 §10.2; NIST AI RMF §Enhance 4.5). **4.2. Control Effectiveness Review:** Periodically evaluate the performance of implemented controls and update regularly as per the threat landscape (ISO/IEC 27001 §A.12.6; ENISA §6.4). **4.3. Audit and Compliance**: To meet regularly and compliance requirements need to conduct internal and external audits (EU AI Act §14–18; ISO/IEC 42001 §10.3).

5.	**Knowledge Management and Learning**	**5.1. Lessons Learned:** Maintain records of incidents and controls to improve risk management practices (ISO 31000 §8; ENISA §6.5). **5.2. Training and Awareness:** Regularly launch awareness campaigns and training to educate employees about threat actors (ISO/IEC 42001 §9.3; NIST AI RMF §Enhance 4.5). **5.3. Continuous Improvement Loop**: Keep updating the latest trends and techniques and continuously improve AI systems (ISO/IEC 42001 §10.4; NIST AI RMF §Enhance 4.5).

Implementation guidance for SMEs

- Implement lightweight mitigation controls suitable for small teams and budgets.
- Use open-source or cloud-based monitoring tools to track AI model performance and anomalies.
- Conduct quarterly reviews of AI controls, risk registers, and audit logs.
- Train staff in incident response procedures and ethical AI usage.
- Maintain documentation for regulatory compliance and audits.

Expected outcomes

- Mitigated AI risks through technical, operational, and organizational controls.
- Effective incident response and resilient AI systems.
- Continuous monitoring for evolving risks and performance degradation.
- Regulatory and ethical compliance for AI deployments.
- Organizational learning embedded in AI risk management practices.

5 Evaluation and Discussion

5.1 Evaluation approach

The purpose of the evaluation is to find out and determine whether the proposed AIS-RMF framework meets the required needs and fulfills the objective of SMEs AI security. Due to the unique requirements of SMEs, there are limited financial and technical resources, making it important to manage AI risk in an efficient and lightweight manner while ensuring compliance and ethical requirements.

A qualitative approach was used for the evaluation of AIS-RMF, supported by comparative analysis with existing frameworks. The main focus was on comparative analysis that finds out the gaps in existing frameworks and ensures that the AIS-RMF covers and fulfills the needs of SMEs. This evaluation also focuses on theoretical and practical considerations and applicability that is important for small and medium enterprises, including startups

5.2 Key objectives of evaluation

Key objectives are mentioned below in detail:

1. **Assess coverage of the framework:** The main objective of the evaluation is to assess the critical components of AI security risk management to be addressed and meet the criteria and objectives of this research, and critical components like governance, risk management, mitigation, and monitoring are addressed on behalf of SMEs.
2. **Determine SME applicability:** The second main purpose of this evaluation is to determine whether the proposed framework is fully fulfilling the needs of SMEs within limited technical and financial resources.
3. **Ensure alignment with standards:**
   And assess the proposed framework AIS-RMF aligns with international standards and guidelines, including:
   a. NIST AI Risk Management Framework (RMF 1.0, 2023)
   b. ISO/IEC 42001:2023 AI Management Systems
   c. ISO/IEC 27005:2022 Information Security Risk Management
   d. EU AI Act (2024)

4. **Identify benefits and challenges:**
   Identify and analyze the potential limitations, ease of implementation, resource efficiency, and scalability.

5.3 Evaluation criteria

The evaluation criteria (Table 7) focus on effectiveness and alignment with industries, best practices, and standards, which align with SMEs' AI security requirements and needs. These criteria contain systematic evaluation and defined procedures that contain the assessment of simplicity, scalability, feasibility, and resource efficiency components.

Table 7: Evaluation Criteria

Criterion	Description	Relevance to AIS-RMF
Relevance	Measures whether the framework addresses the critical AI risk management needs of SMEs, including governance, data, AI assets, risk, and mitigation.	Each function (Govern, Identify, Assess, Strength) ensures coverage of all key SMEs AI risks, from governance accountability to technical threat detection.
Comprehensiveness	Determines if the framework adequately covers governance, compliance, ethical, operational, and technical aspects of AI security.	Functions are designed to map AI assets, assess risks, enforce controls, and ensure continuous improvement, covering all relevant dimensions.
Simplicity and scalability	Evaluates whether SMEs can easily adopt and scale the framework as their AI maturity grows.	AIS-RMF is modular and lightweight, allowing SMEs to start with basic governance and asset mapping and gradually include advanced risk assessment and mitigation.
Feasibility	Assesses if SMEs can implement the framework given limited resources, personnel, and technical expertise.	Provides practical implementation steps, templates, and lightweight procedures, ensuring adoption without overburdening SMEs.
Alignment	Checks whether the framework aligns with recognized standards and regulations, including NIST AI RMF, ISO/IEC 42001, ISO/IEC 27005, ENISA, and EU AI Act.	AIS-RMF maps each function and subfunction to standards and regulatory requirements, ensuring compliance and credibility.

Value addition	Evaluates the benefits SMEs gain by implementing the framework, including reduced risk, improved compliance, and enhanced operational efficiency.	Functions support proactive risk identification, decision-making, and continuous improvement, providing measurable value for SMEs.
Resource efficiency	Measures whether the framework is cost-effective and efficient, minimizing time, effort, and personnel demands.	Lightweight design ensures that risk assessments, asset mapping, and mitigation measures can be performed without extensive human or financial resources.

5.4 Evaluation methodology

A Comparative analysis has been chosen for the evaluation methodology that focuses on comparison with existing well-known industry frameworks, standards, and guidelines to ensure best practices for SMEs.

Process:

- Map framework components (Govern, Identify, Assess, Strength) against ISO/IEC 42001, NIST AI RMF, ENISA, and other guidelines.
- Identify strengths, gaps, and redundancies in the proposed framework.
- Focus on SME-specific requirements such as simplicity, cost-effectiveness, and limited staffing.

Rationale: Comparative analysis ensures that AIS-RMF is aligned with global best practices while remaining lightweight for small organizations.

5.5 Comparative analyses with existing frameworks

5.5.1 AI governance and accountability

Both well-known standards **ISO/IEC 42001** and **NIST AI RMF** focus on governance in a well-structured manner that involves dedicated compliance officers preparing documentation, regularly auditing. Although these practices are efficient and provide accountability but often require a lot of resources in terms of dedicated compliance to officers, team members, and expensive tools.

The proposed framework, AIS-RMF, provides lightweight governance models where an existing managerial role can handle leadership, compliance, and risk management functions without any expertise in governance and compliance. The AI-RMF provides a list of guidelines in the Governance function that help in managerial roles at each step and follow the guidelines and take actions as per the instructions. This approach ensures fulfilling all governance-related tasks without any expert roles and can hold accountability, transparency, and trustworthiness while minimizing managerial burden (ISO/IEC 42001:2023; NIST AI RMF, 2023).

5.5.2 Risk identification and mapping

The core component of **NIST AI RMF** and **ISO/IEC 27005** is risk identification and asset inventory, which requires a typical expert in risk analysis to have a comprehensive tool for threat and inventory management.

The framework coordinates all these activities in a single identity function. SMEs can identify all assets, including threats, using low-cost and open-source tools, including spreadsheets. This enables small and medium enterprises to explore all the AI infrastructure and associated threats without any financial or technical expertise requirements.

5.5.3 Data security and privacy

The well-known standards and guidelines, such as **ISO/IEC 42001** and the **EU AI Act (2024),** establish the sticks governance and privacy requirements for the data. Organizations within the EU most probably rely on GDPR that pay strict attention to data leakages and compliance.

This framework focuses on risk risk-based data classification approach that prioritizes the data as per their criticality and sensitivity on behalf of business operations. After prioritizations, the classified data is taken into consideration for further steps. This process eliminates unnecessary data management that saves time, effort, and a lot of other resources. SMEs can use existing privacy tools, including open source compliance libraries to manage data in use, transit and at rest mood by holding confidentiality, integrity, and availability of data. These implications ensure the alignment with the regulatory and compliance requirements without the need for a specialized data protection department.

5.5.4 Model robustness, fairness, and performance

The existing framework and standards **ISO/IEC 42001** and **NIST AI RMF** focus on quantitative evaluation of model robustness and fairness, while using advanced testing frameworks. These methods require a lot of resources and infrastructure that may exceed the capacity of SMEs.

The AIS-RMF function focuses on open-source bias detection tools to fulfill the fairness and performance evaluation requirement by using periodic testing. These activities are adopted under the normal AI development cycle to verify fairness. SMEs continuously monitor the performance and trustworthiness of the models to align with regulatory and compliance requirements.

5.5.5 Resource efficiency and simplicity

The existing standards and guidelines use skilled team members as well as technical departments to deal with these kinds of risk management activities. In contrast, AIS-RMF functions provide simplicity and ensure resource efficiency because each function, Govern, identify, Assess, and Strength, can operate with a single memory that can be an IT guy or any medium-level security expert, which allows incremental adoption based on available resources. The documentation is limited to providing efficiency by using templates instead of extensive log audit trails.

The modules and functions enable AIS-RMF to integrate the AI risk management process with daily operations without any disturbance and without requiring financial investment or resources.
These functions provide the facility for SMEs to use a structured framework that holds instructions

and guidelines to fulfill the organization's AI security management needs and strengthen the security of AI in small and medium enterprises, including startups.

5.5.6 Regulatory alignment and compliance

Despite the simplicity and limited resources, AIS-RMF provides facilities to medium and small organizations aligned with the industry's standards and best practices, such as ISO/IEC 42001, ISO/IEC 27005, and the EU AI Act (2024). Alignment with these standards and guidelines helps SMEs progress and their AI security and governance when engaging with partners that require the alliance with international best practices.

5.5.7 Monitoring and continuous improvement

Continuous improvement and monitoring are also offered by existing frameworks like NIST AI RMF and ISO/IEC 42001. However, they provide this facility based on external audits and involve extra tools and technologies with the help of dedicated employees. But AIS-RMF monitors continuous improvement using open source tools and implements an internal self-assessment due to limited resources.

Without needing formal auditing services, SMEs can refine their AI risk management activities by using continuous learning and adaptation. It also ensure that organizations are up-to-date for proactive security awareness.

5.5.8 Summary of findings

Comparative evaluation results show that the proposed framework AI as I don't know covers core principles of leading AI risk management frameworks, such as governance, accountability, continuous improvement, and transparency, which optimize resource efficiency, scalability, and simplicity.

- It aligns conceptually and structurally with ISO/IEC 42001, NIST AI RMF, and ENISA AI Cybersecurity Guidelines.
- It reduces implementation complexity through modular functions and lightweight documentation.

- It ensures the alignment with industry's best standards and regulatory and compliance requirements.
- It provides a clear path for small and medium organizations and focuses on their AI security needs within the limited budget and technical resources.

Table 8 shows the comparative analysis between industries best standards and the proposed fireworks AIS-RMF based on the criteria for evaluation.

Table 8: Evaluation Results

Criterion	**ISO/IEC 42001**	**NIST AI RMF**	**ENISA AI Security**	**AIS-RMF (Proposed)**
Complexity	High	Moderate	Moderate	**Low**
Suitability for SMEs	Limited	Partial	Partial	**High**
Scalability	Medium	High	Medium	**High**
Resource efficiency	Moderate	Moderate	Moderate	**High**
Compliance alignment	Excellent	Excellent	Good	**Excellent**
Ease of implementation	Moderate	Moderate	Moderate	**High**

5.6 Alignment with research objectives

AIS-RMF has successfully completed all the research objectives that were defined in Chapter 1. The summary of these objectives is:

Objective 1 – Develop a lightweight AI security risk management framework:
The proposed framework, AIS-RMF, was evaluated as per the defined criteria and met all the requirements defined by SMEs. AIS-RMF has achieved this objective with a different process. First, performed the study of existing AI security risk management literature and standards, and then found the gaps between these frameworks to customize on behalf medium and small organizations to manage AI Security risk management within limited resources and requirements.

Objective 2 – Ensure alignment with international standards:
This framework includes the essential components that were collected from the well-known

standards, guidelines, and frameworks, and shaped into well-structured and implemented within fewer sources and requirements for small and medium enterprises, which maintain regulatory and compliance requirements by following international best practices.

Objective 3 – Enhance relevance for SMEs:

The frameworks accomplish this objective by fulfilling the needs of small and medium enterprises, including startups. It's analyzed and evaluated as per different criteria and illustrated that complexity is low and resource efficient, and the ease of implementation is high. These evaluation results clearly indicate that this proposed framework fully meets the required objective of SMEs AI security risk management.

5.7 Limitations and recommendations for future research

There were several limitations identified during the evaluation process, although the framework is strong enough, but also needs to pay attention to these limitations:

- **Lack of empirical testing**: Implication of this framework into real-world scenarios is mandatory. Although this framework is assessed on comparative analysis with existing standards and frameworks. Pilot studies are needed to further validate. It may be part of the next plan.
- **Contextual variability:** The framework might require customization based on industrial operations because some industries have unique regulatory and operational requirements, such as healthcare, manufacturing, and finance.
- **Dependence on organizational culture:** Although the proposed framework is super-efficient, but also requires a good culture in the organizations to take serious actions and complications of this framework, without proper internal communication and training, it may not be fully efficient.
- **Evolving AI and security landscape:** As AI rules and regulations are changing day by day, which a need to stay aligned with new standards and rules.

Despite these challenges, the proposed framework provides the first-ever AI security risk management framework that focuses on organizations that are based on their limited resources

and technical abilities to face and manage AI-related threats and risks that can cause major danger in the ever-evolving landscape of AI Security.

6 Conclusion

In the digital landscape, small and medium enterprises are rapidly growing by using AI for automation, data processing, and machine intelligence. This adoption of AI is also increasing the high-level technical and non-technical risks. Large organizations and enterprises have dedicated departments, skilled labor, and the resources to mitigate, address, and control emerging AI risks. But the small and medium enterprises, including startups, have limited resources, no dedicated departments or skilled labor to tackle these AI issues. So, in small and medium enterprises, a need was discovered for security risk management to be implemented within the required resources and constraints.

To meet the requirements of small and medium enterprises, a lightweight AI security risk management framework was developed and evaluated under certain conditions that fulfill the needs of small and medium-sized businesses to tackle AI security.

This AIS-RMF ensures that the SMEs doesn't require complexity in the risk management process. It focuses only on clarity, structure, and alignment with organizational capacity. The developed AIS-RMF focuses on SMEs to support innovation and responsibility while promoting a safer, more ethical, and sustainable AI ecosystem. After implementing the developed AIS-RMF, companies can play a pivotal role and ensuring security governance and trust in the digital transformations, not as a barrier but as an example for the long-term achievements and success.

6.1 Summary of the research

The main purpose of developing this AI security risk management framework is to support SMEs in their AI security risk management process. For this purpose, the existing frameworks, standards, and guidelines were analyzed and collected unique components that are tailored for SMEs, while the existing frameworks are comprehensive, complex, and resource-intensive, making them unsuitable for SMEs with limited resources and technical capacity.

The developed AIS-RMF is a modular, resource-efficient, and scalable framework that addresses the gaps and implements the AI security risk management process in a structured and well-managed way.

The study followed a multi-step approach:

1. **Literature review:**
   In the first process, the existing framework was analyzed and assessed as per the small and medium organizational requirements and the gaps due to high operational and dedicated technical and financial resources. So, during comparative analysis, unique components were identified, particularly for SMEs are requirements.

2. **Framework design:**
   After comparative analysis, the unique guidelines and instructions were collected and built in a structured manner for the AI security of small and medium organizations. So, in this process, the collected components are categorized into four functions, including Governance, Identity, Access, and Strengthen. These functions provide an overall view for risk management that contains approaches and guidelines to fulfill the SMEs' requirements. The first function focuses on governance and accountability and then moves to the next function for asset identification and threat analysis. The identified threats are measured and prioritized in the assessment function, and in the final stage of iteration, help to apply controls and mitigation strategies to enhance the security in strength system. This is an iterative process that applies to AI to make sure risks are identified, assessed, and mitigated during AI lifecycle.

3. **Evaluation and discussion:**
   Comparative analysis was conducted between existing standards and the newly created AIS-RMF to assess how well the AIS-RMF framework aligns with international standards and meets SMEs-specific requirements for simplicity, scalability, and regulatory alignment. These evaluations show the AIS-RMF is easy to implement, resource-efficient efficient and less complex than full fill the need that was required.

Finally, a structured framework was developed that contains the instructions and guidelines for small and medium organizations to follow and implement AI security risk management practices with limited resources.

References

European Commission. (2003). *Commission Recommendation 2003/361/EC concerning the definition of micro, small and medium-sized enterprises*. Official Journal of the European Union. https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:32003H0361

European Startup Network. (2022). *The European startup definition and characteristics*. Retrieved from https://europeanstartupnetwork.eu

Iqbal, J., & Abbas, A. (2025, April 1). *Cybersecurity and AI Synergy for SME Resilience and Economic Equality*. https://doi.org/10.13140/RG.2.2.23500.12166

European Commission. (2020). *Recommendation 2003/361/EC concerning the definition of micro, small and medium-sized enterprises.* Official Journal of the European Union. https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX%3A32003H0361

Sarker, I. H., Janicke, H., Mohsin, A., & Maglaras, L. (2025). *SME-TEAM: Leveraging trust and ethics for secure and responsible use of AI and LLMs in SMEs.* arXiv. https://arxiv.org/abs/2509.10594

Somer, P., & Thalmann, S. (2023). *Risk management of AI in industry: A literature review.* In *MCIS 2023 Proceedings* (Paper 27). Association for Information Systems. https://aisel.aisnet.org/mcis2023/27

Sotamaa, T., Reiman, A., & Kauppila, O. (2023). Manufacturing SME risk management in the era of digitalisation and artificial intelligence: A systematic literature review. *Continuity and Resilience Review, 5*(4), 340–356. https://doi.org/10.1108/CRR-12-2023-0022

Zeijlemaker, S., Lemiesa, Y. K., Schröer, S. L., Abhishta, A., & Siegel, M. (2025). How does AI transform cyber risk management? *Systems, 13*(10), 835. https://doi.org/10.3390/systems13100835

Žigienė, G., Rybakovas, E., & Alzbutas, R. (2019). Artificial intelligence-based commercial risk management framework for SMEs. *Sustainability, 11*(16), 4501. https://doi.org/10.3390/su11164501

ENISA. (2023). *AI cybersecurity: Securing artificial intelligence systems.* European Union Agency for Cybersecurity. https://www.enisa.europa.eu

European Commission. (2020). *Annual report on European SMEs 2019/2020: Building a sustainable recovery*. Publications Office of the European Union.

National Institute of Standards and Technology. (2023, July 12). *AI Risk Management Framework*. NIST. https://www.nist.gov/itl/ai-risk-management-framework

International Organization for Standardization. (2022). ISO/IEC 27005:2022 Information security, cybersecurity and privacy protection — Guidance on information security risk management. ISO. https://www.iso.org/standard/80585.html

International Organization for Standardization. (2023). ISO/IEC 42001:2023 Artificial intelligence management system — Requirements. ISO. https://www.iso.org/standard/81230.html

Braun, V., & Clarke, V. (2006). Using thematic analysis in psychology. *Qualitative Research in Psychology, 3*(2), 77–101. https://doi.org/10.1191/1478088706qp063oa

Creswell, J. W., & Creswell, J. D. (2018). Research design: Qualitative, quantitative, and mixed methods approaches (5th ed.). SAGE Publications.

Hevner, A. R., & Chatterjee, S. (2010). Design research in information systems: Theory and practice. Springer. https://doi.org/10.1007/978-1-4419-5653-8

Hevner, A. R., & Chatterjee, S. (2010). *Design research in information systems: Theory and practice.* Springer. https://doi.org/10.1007/978-1-4419-5653-8

EU's Artificial Intelligence (AI) Act - Civilsdaily. (2023, May 4). CivilsDaily. https://www.civilsdaily.com/news/eus-artificial-intelligence-ai-act/

Bender, E. M. (2021). On the dangers of stochastic parrots: Can language models be too big? *Proceedings of the 2021 ACM Conference on Fairness, Accountability, and Transparency*, 610-623. https://doi.org/10.1145/3442188.3445922

Carlini, N., Tramer, F., Wallace, E., Jagielski, M., Herbert-Voss, A., Lee, K., Roberts, A., Brown, T., Song, D., Erlingsson, U., Oprea, A., & Raffel, C. (2021). Extracting training data from large language models. *Proceedings of the 30th USENIX Security Symposium*, 2633-2650. https://www.usenix.org/conference/usenixsecurity21/presentation/carlini-extracting

Goodfellow, I., McDaniel, P., & Papernot, N. (2020). Making machine learning robust against adversarial inputs. *Communications of the ACM, 63*(7), 56-66. https://doi.org/10.1145/3134599

Google. (2018). *AI at Google: Our principles*. https://ai.google/principles/

Google. (2023). *Perspective on AI risk management*. https://ai.google/static/documents/perspective-on-ai-risk-management.pdf

ICO. (2022). *AI and data protection risk toolkit*. Information Commissioner's Office. https://ico.org.uk/for-organisations/uk-gdpr-guidance-and-resources/artificial-intelligence/ai-and-data-protection-risk-toolkit/

IMDA & PDPC. (2020). *Model AI governance framework* (2nd ed.). Infocomm Media Development Authority & Personal Data Protection Commission. https://www.pdpc.gov.sg/Help-and-Resources/2020/01/Model-AI-Governance-Framework-Second-Edition

Kraus, J., Scholz, D., Stiehler, A., & Stoeck, D. (2021). A socio-technical framework for assessing AI risk. In *Proceedings of the 54th Hawaii International Conference on System Sciences* (pp. 5765-5774). http://hdl.handle.net/10125/71321

Microsoft. (2022). *Responsible AI Standard, v2*. https://blogs.microsoft.com/wp-content/uploads/prod/sites/5/2022/06/Microsoft-Responsible-AI-Standard-v2-General-Requirements-3.pdf

MITRE. (2023). *ATLAS (Adversarial Threat Landscape for Artificial-Intelligence Systems)*. https://atlas.mitre.org/

OWASP. (2023). *OWASP AI security and privacy guide*. https://owasp.org/www-project-ai-security-and-privacy-guide/

Papernot, N., McDaniel, P., Sinha, A., & Wellman, M. P. (2018). SoK: Security and privacy in machine learning. In *2018 IEEE European Symposium on Security and Privacy (EuroS&P)* (pp. 399-414). IEEE. https://doi.org/10.1109/EuroSP.2018.00035

Sarker, I. H., Janicke, H., Mohsin, A., & Maglaras, L. (2025). SME-TEAM: Leveraging trust and ethics for secure and responsible use of AI and LLMs in SMEs. *arXiv preprint*. https://arxiv.org/abs/2509.10594

Smith, B. (2023). *Tools and weapons: The promise and the peril of the digital age*. Penguin Press.

Sobers, R. (2023). *The OWASP AI security guide: What developers need to know*. VeraCode Blog. https://www.veracode.com/blog/secure-development/owasp-ai-security-guide-what-developers-need-know

Stokes, J. W. (2022). *Adversarial machine learning: A taxonomy and terminology of attacks and mitigations* (NIST AI 100-2). National Institute of Standards and Technology. https://doi.org/10.6028/NIST.AI.100-2

Tan, G. S. (2023). Singapore's model AI governance framework: A comparative analysis with the EU AI Act. *Asian Journal of Law and Technology, 12*(1), 45-67.

Wachter, S., Mittelstadt, B., & Russell, C. (2021). Why fairness cannot be automated: Bridging the gap between EU non-discrimination law and AI. *Computer Law & Security Review, 41*, 105567. https://doi.org/10.1016/j.clsr.2021.105567

Bellamy, R. K. E., Dey, K., Hind, M., Hoffman, S. C., Houde, S., Kannan, K., ... & Zhang, Y. (2019). AI Fairness 360: An extensible toolkit for detecting, understanding, and mitigating unwanted algorithmic bias. *IBM Journal of Research and Development*, 63(4/5), 4:1-4:1